

Design review checklist for Security

This checklist presents a set of security recommendations to help you ensure your workload is secure and aligned with the Zero Trust model. If you haven't checked the following boxes and considered the tradeoffs, then your design might be at risk. Carefully consider all of the points covered in the checklist to gain confidence in your workload's security.

Checklist

[Expand table](#)

Code	Recommendation
☐ SE:01	Establish a security baseline that's aligned to compliance requirements, industry standards, and platform recommendations. Regularly measure your workload architecture and operations against the baseline to sustain or improve your security posture over time.
☐ SE:02 SE:02	Align secure development lifecycle (SDL) throughout the software development lifecycle to ensure confidentiality, integrity, and availability of software and adopt a security-first mindset.
☐ SE:03	Classify and consistently apply sensitivity and information type labels on all workload data and systems involved in data processing. Use classification to influence workload design, implementation, and security prioritization.
☐ SE:04	Create intentional segmentation and perimeters in your architecture design and in the workload's footprint on the platform. The segmentation strategy must include networks, roles and responsibilities, workload identities, and resource organization.
☐ SE:05	Implement strict, conditional, and auditable identity and access management (IAM) across all workload users, team members, and system components. Limit access exclusively to <i>as necessary</i> . Use modern industry standards for all authentication and authorization implementations. Restrict and rigorously audit access that's not based on identity.
☐ SE:06	Isolate, filter, and control network traffic across both ingress and egress flows. Apply defense-in-depth principles by using localized network controls at all available network boundaries across both east-west and north-south traffic.
☐ SE:07	Encrypt data by using modern, industry-standard methods to guard confidentiality and integrity. Align the encryption scope with data classifications, and prioritize native platform encryption methods.
☐ SE:08	Harden all workload components by reducing extraneous surface area and tightening configurations to increase attacker cost.
☐ SE:09	Protect application secrets by hardening their storage and restricting access and manipulation and by auditing those actions. Run a reliable and regular rotation process that can improvise

Code	Recommendation
	rotations for emergencies.
☐ SE:10	Implement a holistic monitoring strategy that relies on modern threat detection mechanisms that can be integrated with the platform. Mechanisms should reliably alert for triage and send signals into existing SecOps processes.
☐ SE:11	Establish a comprehensive testing regimen that combines approaches to prevent security issues, validate threat prevention implementations, and test threat detection mechanisms.
☐ SE:12	Define and test effective incident response procedures that cover a spectrum of incidents, from localized issues to disaster recovery. Clearly define which team or individual runs a procedure.

Next steps

We recommend that you review the Security tradeoffs to explore other concepts.

Security tradeoffs

Last updated on 03/19/2026